

Cloud RedTeam与云安全攻防矩阵

演讲嘉宾 · 李鑫

2021首届-西部云安全峰会
Western China Cloud Security Summit 2021



腾讯安全



腾讯安全云鼎实验室



陕西省计算机学会



About me

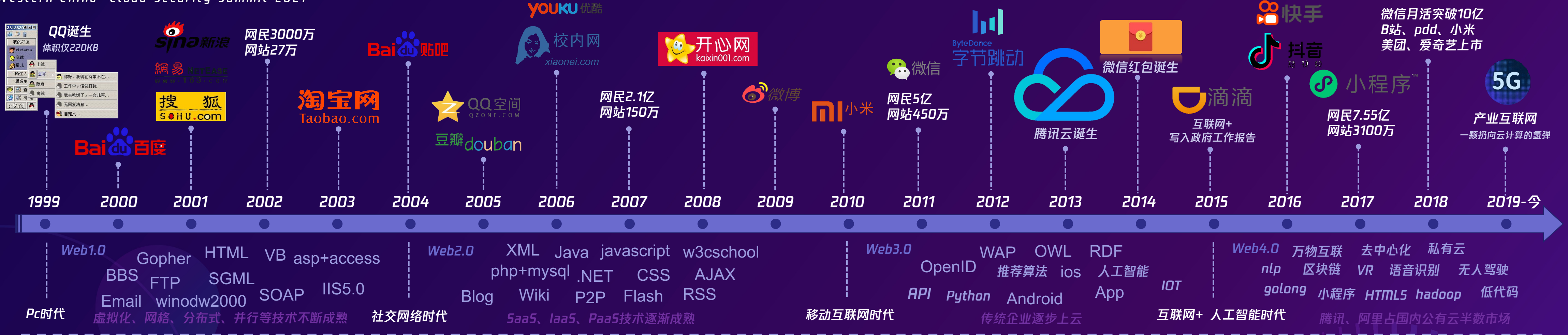
- 近期ID: “牧狼人”
- 研究方向: OSINT开源情报、APT及云上攻防
- 腾讯云鼎实验室攻防负责人, 负责云上攻防技术研究及Cloud RedTeam能力建设;



技术往事：从寻呼机到云计算

2021首届-西部云安全峰会

Western China Cloud Security Summit 2021



安全元年 冲击波病毒 黑客防线 中美黑客大战 灰鸽子 黑客x档案

Web安全 黑产浮现 盗号猖獗 黑客基地 钓鱼网站爆发 社交网络蠕虫 黑客榜中榜 被黑站点统计 世贸官网被黑

移动安全 安卓病毒爆发 匿名者 勒索病毒 棱镜门事件 信息泄漏事件 丝绸之路 震网病毒

红队、APT 希拉里邮件门 SWIFT黑客事件 方程式组织 网络安全法 用户隐私泄露频发



中国被黑站点统计系统			
提交者	组织名	IP	域名
NO1:THEHACKER[122]	西安太子	http://www.sxqzj.com/index.htm	
NO2:ALT[102]	TheHacker	http://51ka.com/Thehacker.htm	
NO3:PLATEAU[108]	TheHacker	http://www.mrm.com.cn/Thehacker.htm	
NO4:WAYKING[105]	ice	http://lqds.cn/inice.asp	
NO5:异域空间[58]	TheHacker	http://vip.aau.cn/Thehacker.txt	
NO6:AMXKJ[50]	TheHacker	http://hnswdx.gov.cn/dht.htm	
NO7:天使神童[42]	TheHacker	http://tw.njut.edu.cn/Thehacker.txt	
NO8:HACKER001[37]	TheHacker	http://www.kkcard.cn/Thehacker.txt	
NO9:漂白色[32]	TheHacker	http://www.lfmj.org.cn/Thehacker.txt	
NO10:蓝色烟火[28]	TheHacker	http://www.hhcb.com.cn/Thehacker.txt	

WooYun.org



从传统攻防到*Cloud RedTeam*的思路转变

传统攻防与云上攻防的区别在哪里

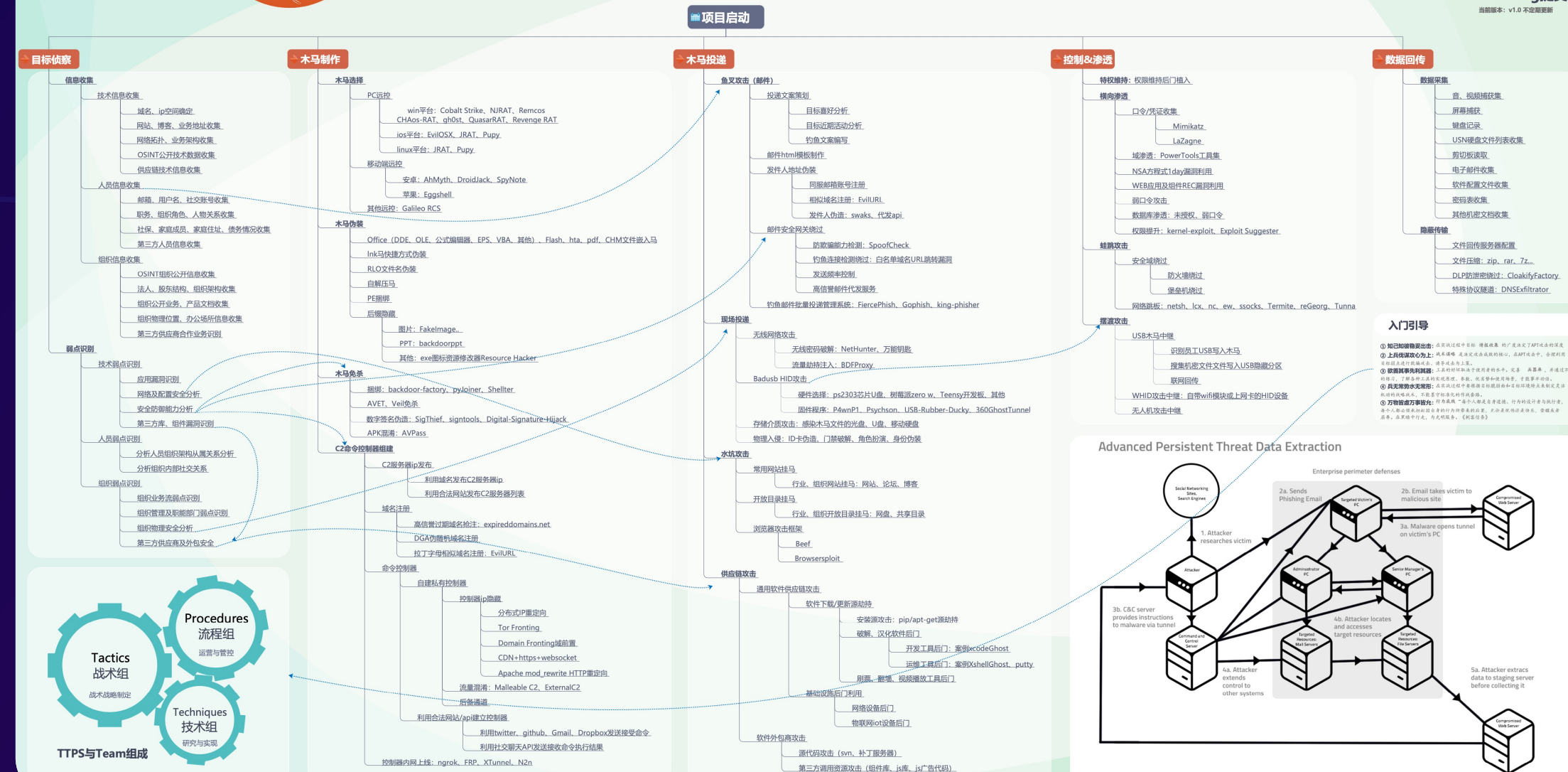


2021首届-西部云安全峰会

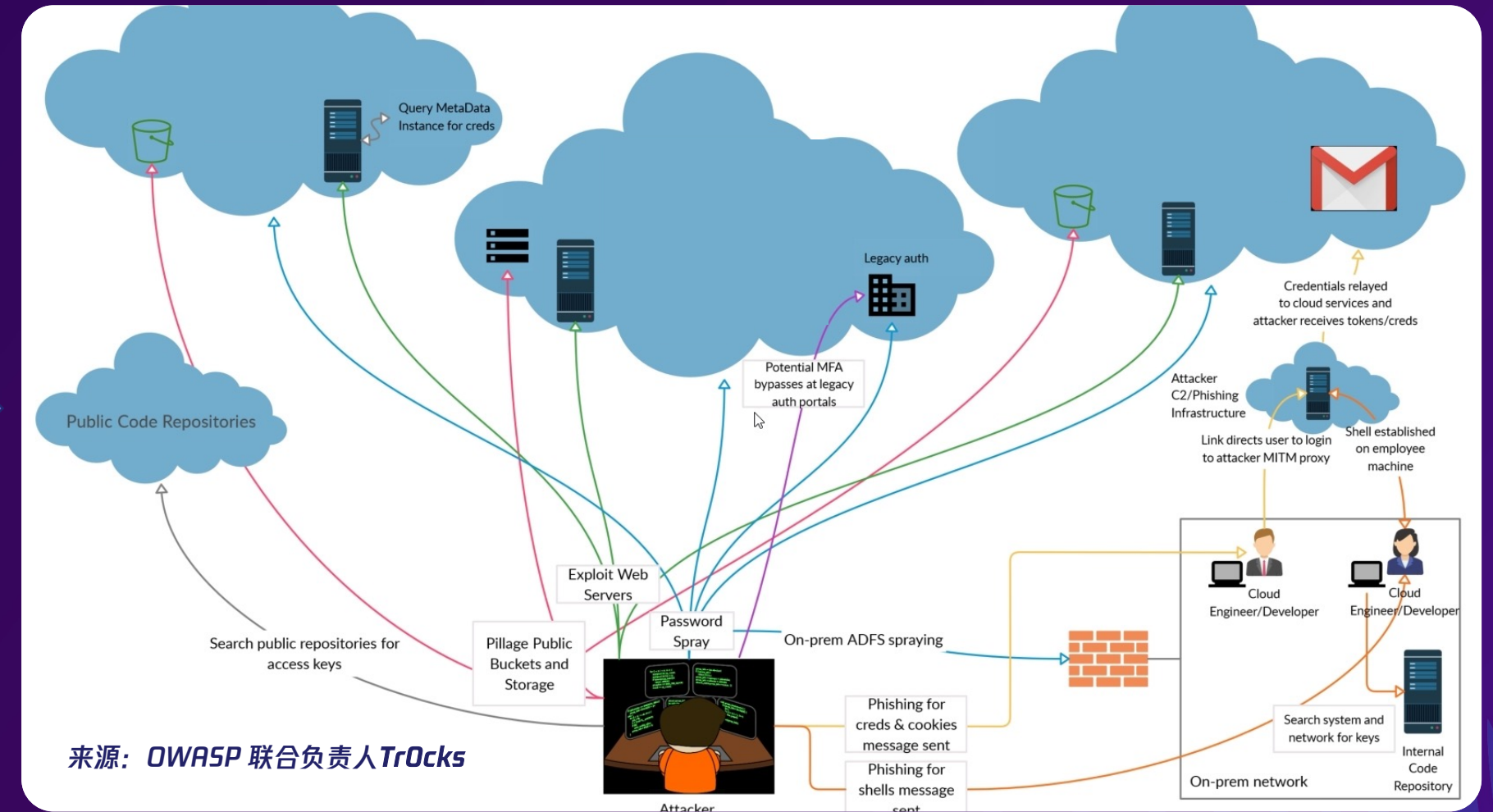
Western China Cloud Security Summit 2021



Idear&bug提交
当前版本: v1.0 不定期更新



从传统红队到云上攻防

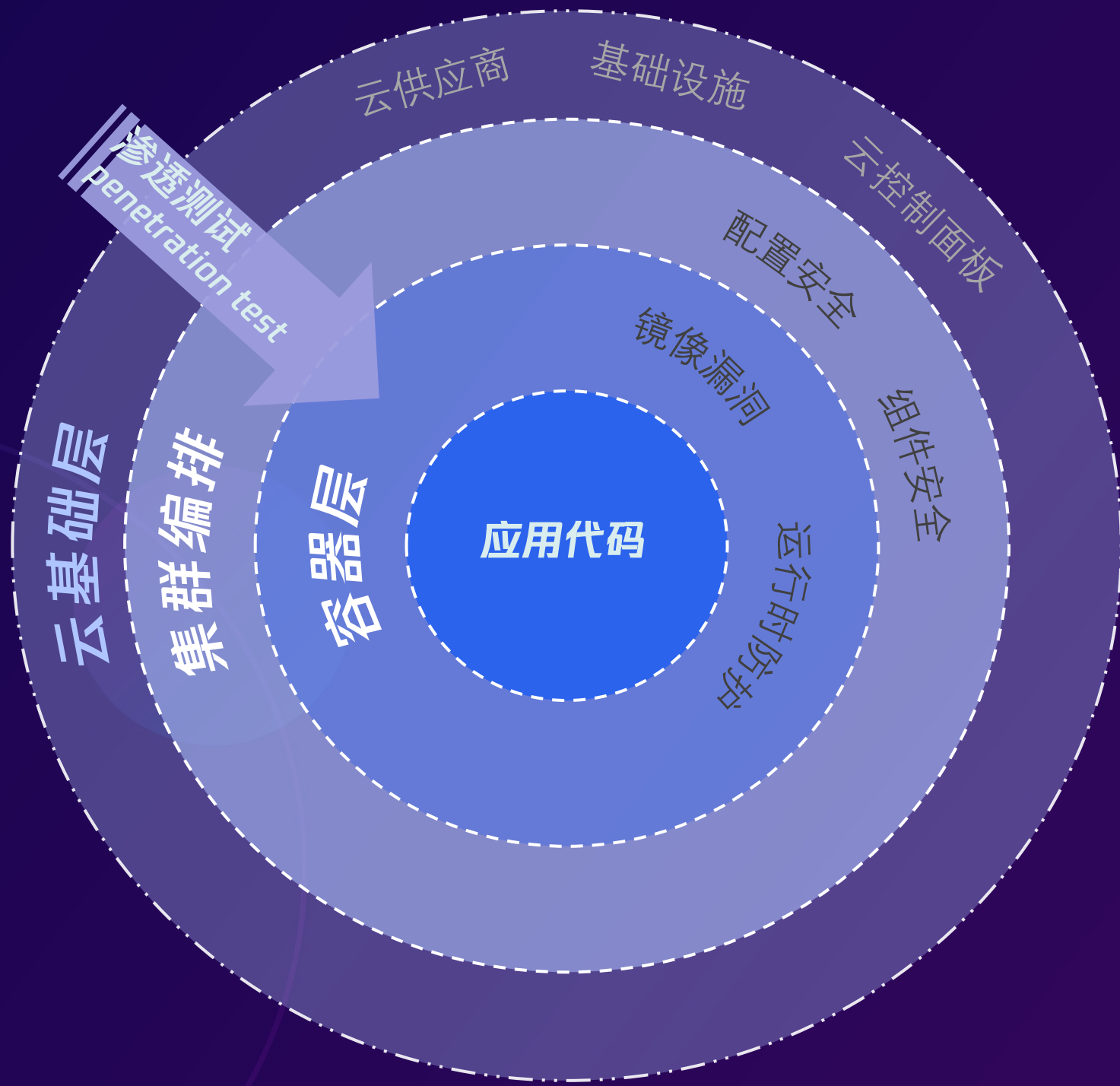


来源: OWASP 联合负责人TrOcks

云计算威胁：云安全到底在关注哪些问题？

01	云计算安全威胁 CSA云安全联盟从宏观角度看云面临哪些安全问题
02	云原生安全威胁 OWASP从云原生的角度看云面临哪些安全问题
03	Web/Api安全威胁 Web/Api是目前实现云业务的最佳方式，其漏洞直接威胁到云
04	产品业务逻辑威胁 产品业务逻辑错综复杂，传统的业务逻辑风险依然是云安全的一大威胁

CSA云计算安全威胁top11	威胁描述及案例
data breaches 数据泄露	描述：数据泄露是指敏感、受保护或机密信息被未经授、权的个人发布、查看、窃取或使用 案例：2019亚马逊云用户CapitalOne公司遭受攻击，导致1亿多客户的个人信息泄露，包括社会安全号码、信用卡号码以及信用评分
misconfigurations and inadequate change control 配置错误和变更控制不足	描述：资产设置不正确导致的一些安全问题 案例：2021年微软Azure Blob云帐户因配置错误泄露总计63GB文件，涉及上百家公司的融资演讲稿以及1多款产品的源代码
lack of cloud security architecture and strategy 缺乏云安全架构和策略配置	描述：业务上云过程中未制定一些适合云环境的安全策略或者架构，导致的安全威胁，如网络隔离 案例：2018年本田汽车Honda Connect应用在使用云存储桶子时未设安全策略，导致50000条以上的用户个人信息泄露
insufficient identity, credential, access and key management 身份，凭证，访问和密钥管理不足	描述：凭据保护不足；缺乏加密密钥、密码和证书的定期自动更新机制；缺乏可扩展的身份、凭据及访问控制系统；无法使用多因子认证方式等 案例：2017年德勤(Deloitte)公司由于凭据和访问管理薄弱导致500万份邮件信息泄露
account hijacking 帐户劫持	描述：针对云账号的劫持，如利用xss、csrf等漏洞控制他人会话进行账户操作 案例：2021年Ubiquiti公司核心账号泄露，攻击者掌控了Ubiquiti位于AWS云上的服务器，造成大量客户账户凭证泄露。
insider threats 内部威胁	描述：内部人员误操作、蓄意破坏 案例：2020年微盟公司员工恶意破坏公司线上生产环境及数据，导致公司系统服务不可用。
insecure interfaces and APIs 不安全的接口和API	描述：云服务的安全性取决于API的安全性，设计不良的API可能会被滥用，甚至造成数据泄漏。 案例：2018年Facebook公司由于预览功能代码中存在凭证窃取漏洞，超5000万用户受影响
weak control plane 脆弱的控制面板	描述：云资产的管理都由控制面板完成，脆弱都控制面板可能导致 案例：2020年Google Cloud Shell存在逃逸漏洞导致用户使用云控制台此功能时受到攻击。
metastructure and applistrucre failures 元结构和应用程序故障	描述：云服务商的元结构(Metastructure)保存了如何保护其系统的安全性信息，并可通过API调用。CSA将元结构称为云服务提供商/客户的“分界线”。这条分界线也是潜在的故障点，可能使攻击者能够访问数据或破坏云客户。 案例：2017年德勤(Deloitte)位于Office 365电子邮件服务的管理员帐户的密码泄露导致大量的客户信息泄露。
limited cloud usage visibility 云使用用途可见性差	描述：当云资产的管理出现盲区时，会导致资产用途不可见，出现影子资产、僵尸资产、非管控资产等问题 案例：2018年云安全专业公司Lacework研究发现超过 22000 个容器编排和 API 管理系统在互联网上是不受保护的或公开可用
abuse and nefarious use of cloud services 滥用和恶意使用云服务	描述：黑灰产及其他网络犯罪使用云服务 案例：使用腾讯云函数打造免费CDN代理池隐藏Cobalt Strike恶意流量绕过防火墙检测



OWASP云原生安全威胁top10

威胁描述及案例

Insecure cloud, container or orchestration configuration
不安全的云、容器或编排配置

案例：〔1〕容器以 root 身份运行；〔2〕容器与主机共享资源；〔3〕不安全的基础设施即代码 (IaC) 配置；

Injection flaws (app layer, cloud events, cloud services)
注入缺陷〔应用层、云事件、云服务〕

案例：〔1〕SQL注入；〔2〕XXE；〔3〕noSQL注入；〔4〕操作系统命令注入；〔5〕无服务器事件数据注入；

Improper authentication & authorization
不正确的认证和授权

案例：〔1〕微服务上未经身份验证的 API 访问；〔2〕过度许可的云 IAM 角色；〔3〕缺乏协调器节点信任规则〔例如未经授权的主机加入集群〕；〔4〕未经身份验证的 Orchestrator 控制台访问；〔5〕未经授权或过度许可的协调器访问；

CI/CD pipeline & software supply chain flaws
CI/CD 管道和软件供应链缺陷

案例：〔1〕CI/CD 管道系统上的身份验证不足；〔2〕使用不受信任的镜像；〔3〕使用陈旧镜像；〔4〕与注册管理机构的不安全通信渠道；〔5〕过于宽松的注册表访问；〔6〕使用单一环境为需要不同安全级别的项目运行 CI/CD 任务；

Insecure secrets storage
不安全的秘密存储

案例：〔1〕Orchestrator 机密存储未加密；〔2〕API 密钥或密码未加密存储在容器内；〔3〕硬编码的应用程序机密；〔4〕未加密的秘密〔例如使用过时的加密方法、使用编码而不是加密等〕；〔5〕安装包包含敏感信息的存储；

Over-permissive or insecure network policies
过度许可或不安全的网络策略

案例：〔1〕允许过度许可的 pod 到 pod 通信；〔2〕暴露于公共互联网的内部微服务；〔3〕未定义网络分段；〔4〕未加密的端到端通信；〔5〕未监控和阻止的未知或潜在恶意域的网络流量；

Using components with known vulnerabilities
使用具有已知漏洞的组件

案例：〔1〕易受攻击的第 3 方开源包；〔2〕应用程序组件的易受攻击版本；〔3〕使用已知易受攻击的容器镜像

Improper assets management
资产管理不当

案例：〔1〕未记录的微服务和 API；〔2〕过时和未受管的云资源

Inadequate ‘compute’ resource quota limits
“计算”资源配额限制不足

案例：〔1〕资源未绑定容器；〔2〕API 上设置的过度许可请求配额

Ineffective logging & monitoring (e.g. runtime activity)
无效的日志记录和监控〔例如运行时活动〕

案例：〔1〕没有容器或主机进程活动监控；〔2〕微服务之间没有网络通信监控；〔3〕无资源消耗监控，确保关键资源的可用性；〔4〕缺乏对编排配置传播和陈旧配置的监控；

云安全攻防矩阵V1.0



PTES
渗透测试执行标准

2011年3月

2011年

网络杀伤链模型发布
Cyber-Kill-Chain



钻石模型发布
Diamond
Model

2013年

2015年5月

ATT&CK矩阵
诞生



MITRE发布云威胁矩阵
ATT&CK for Cloud

2019年10月

2020年4月

微软发布首个
Kubernetes
威胁矩阵

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	lateral Movement	Impact
Using Cloud Credentials	Exec into container	Backend container	Privileged container	Clear container logs	List K8S secrets	Access the K8S API server	Access cloud resources	Data Destruction
Compromised images in registry	backdoor inside container	Writable hostPath mount	Cluster-admin binding	Delete K8S secrets	Mount service principal	Access Kubernetes API	Container service account	Resource Hijacking
Reusing config file	New container	Kubernetes CronJob	hostPath mount	Pod / container name similarity	Access container service account	Network mapping	Cluster internal networking	Denial of service
Application vulnerability	Application exploit (POC)	Access cloud resources	Connect from Proxy server	Applications credentials in configuration files	Access Kubernetes dashboard	Applications credentials in configuration files	Applications credentials in configuration files	
Exposed dashboard	K8s server running inside container				Instance Metadata API	Writable volume mounts on the host	Access Kubernetes dashboard	Access K8s endpoint

国内首个容器
ATT&CK矩阵发布

2020年6月

2021年4月

ATT&CK v9版发布
增加容器部分



美国Stellar Cyber推出
XDR Kill Chain

2021年7月

2021年8月

国内首个K8S
ATT&CK矩阵发布



云安全攻防矩阵v1.0发布

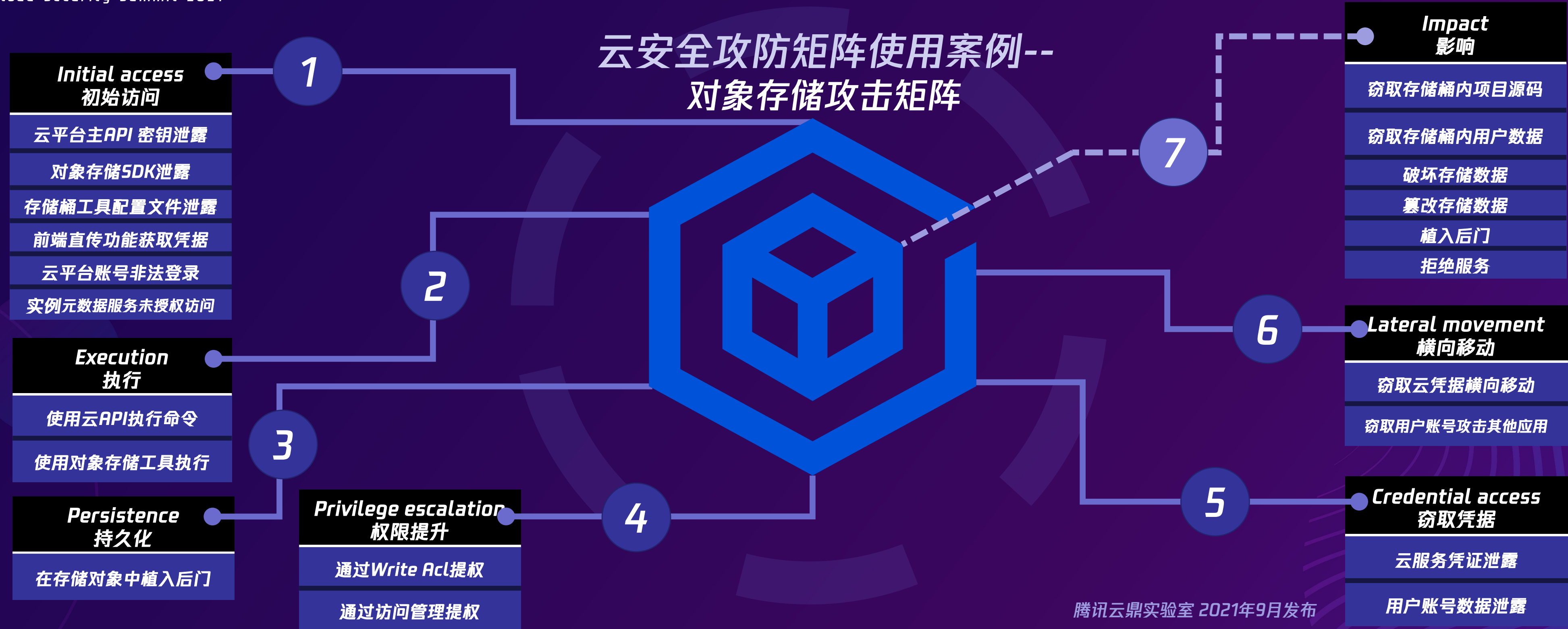
今天

- 通过漏洞数据、攻击事件抽象出攻击模型〔矩阵〕
- 为什么是这种形式？
一种军事杀伤链模型“F2T2EA”演变而来
- 有什么不一样？
关注整个云生态

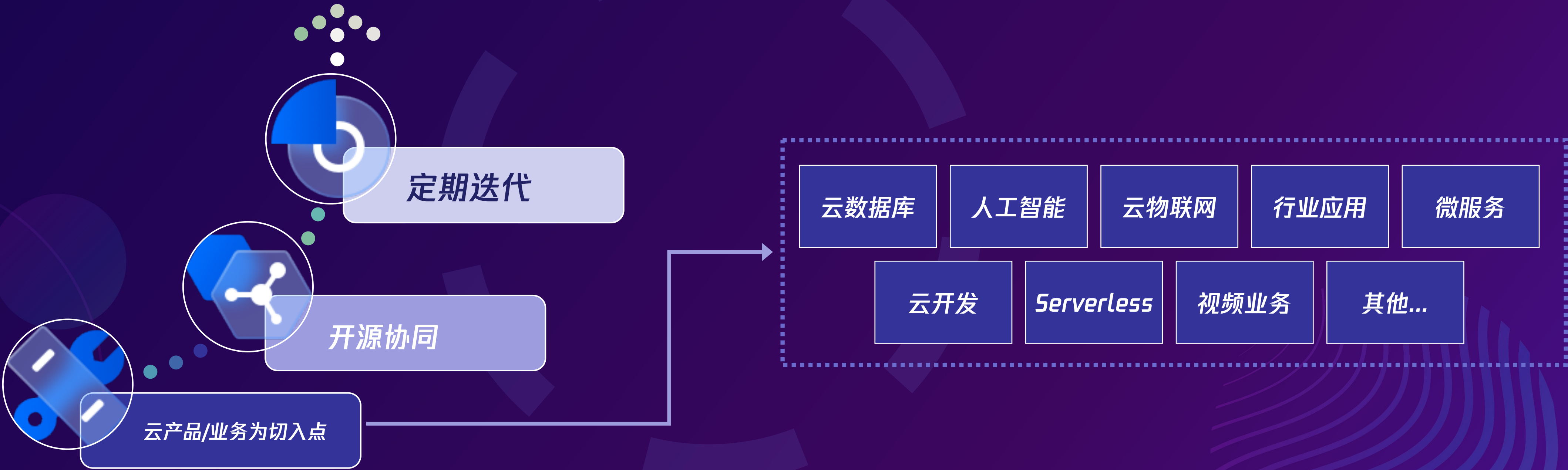


云安全攻防矩阵 v1.0

初始访问	执行	持久化	权限提升	防御绕过	窃取凭据	探测	横向移动	影响
实例登录信息泄露	登录云服务器实例执行指令	云服务器实例中部署远控客户端	修改policy策略	禁用日志记录	获取服务器实例登录账号	探测云厂商服务接口	使用实例账号爆破	数据泄漏
账户劫持	写入userdata执行命令	在userdata中添加后门	sqlserver提权	监控区域外创建实例	元数据服务获取角色临时凭据	内网扫描	通过控制台权限横向移动	资源劫持
网络钓鱼	利用后门文件执行指令	为现有用户分配额外的密钥创建新实例	利用操作系统漏洞进行提权	关闭全球服务事件监视	获取K8s configfile	探测Kubernetes Dashboard	窃取角色临时凭据横向访问	网络逃逸
应用程序漏洞	利用数据库应用执行命令	为现有用户分配额外的密钥	利用特权容器提权	关闭主机安全产品	元数据服务获取角色临时凭据	探测 Kubernetes APIServer	通过漏洞逃逸到宿主机	拒绝服务
利用恶意或存在漏洞的自定义镜像	利用SSH服务进入实例执行	建立辅助账号登录	利用错误配置提权	日志清理	用户账号数据泄露	内网扫描	通过配置错误逃逸到宿主机	数据丢失
应用程序漏洞	利用远程代码执行漏洞执行	通过容器逃逸向宿主机写入文件	利用操作系统漏洞提权	关闭容器安全产品	获取配置文件中的应用凭证		通过K8s Dashboard横向移动	服务滥用
利用恶意或存在漏洞的自定义镜像	部署后门容器	在自定义镜像库中镜像植入后门	利用Kubernetes 漏洞进行提权	常规Pod中植入后门	云服务凭证泄露		窃取角色临时凭据访问云服务	权限接管
利用暴露的 K8s控制面板	进入容器执行	K8s 定时任务	利用Docker漏洞提权	日志清理			窃取用户账号攻击其他应用	
kubeconfig文件泄露	利用SSH服务进入容器执行	在存储对象中植入后门	通过Write Acl提权	通过代理访问			窃取凭据访问云服务	
对象存储SDK泄露	利用远程代码执行漏洞执行		通过访问管理提权				窃取用户账号攻击其他应用	
存储桶工具配置文件泄露	使用云API执行命令							
前端直传功能获取凭据	使用云厂商工具执行							
实例元数据服务未授权访问							云服务器攻击方式	
云平台账户泄露							容器攻击方式	
云API 密钥泄露							存储攻击方式	
							共同攻击方式	



云安全攻防矩阵未来计划--



感谢聆听
Thanks

● 2021首届-西部云安全峰会
Western China Cloud Security Summit 2021